

Abstract

Mit Threat-Informed Defense (TID) wird ein praxisorientierter Ansatz verfolgt, der Unternehmen eine zielgerichtete Priorisierung der Schutzmaßnahmen ermöglicht. Anstatt sich ausschließlich auf generische Schutzmaßnahmen zu verlassen, orientiert sich Threat-Informed Defense gezielt an realen, durch Angreifer angewendeten Taktiken, Techniken und Verfahren (engl. TTPs). Auf dieser Basis entsteht ein risikobasiertes Konzept, welches die IT-Sicherheit nachhaltig stärkt. Dieses Whitepaper richtet sich an Entscheidungsträger im Unternehmen.

Aktuelle Lage

Die IT-Sicherheit leidet oft an fehlender Fokussierung. Fast täglich werden neue (teilweise) kritische Schwachstellen - darunter auch Zero-Day-Exploits - öffentlich, während Unternehmen und Behörden zunehmend Ziele von Cyberangriffen werden. Um auf die angespannte Lage zu reagieren, definieren Gesetzgeber und Regulierungsbehörden neue gesetzliche oder regulatorische Anforderungen. Dennoch kommt es auch bei Unternehmen, die hohe Budgets für die IT- und Informationssicherheit bereitstellen und ein zertifiziertes ISMS aufweisen, immer wieder zu teilweise gravierenden Vorfällen.

Was ist Threat-Informed Defense?

Threat-Informed Defense ist ein Sicherheitsansatz, der auf der kontinuierlichen Analyse realer Angreifertechniken basiert. Ziel ist es, Verteidigungsmaßnahmen so auszurichten, dass sie gezielt gegen bekannte Bedrohungen wirken.

Der Ansatz stellt die Frage:

“Wie würde ein Angreifer mein Unternehmen konkret angreifen - und bin ich darauf vorbereitet?”

Threat-Informed Defense kombiniert folgende drei Säulen miteinander:

- Threat Intelligence (aktuelle Informationen über Angreifer)
- Angriffs- und Bedrohungsmodellierung (z. B. *MITRE ATT&CK*)
- Security Engineering (gezielte Maßnahmen zur Abwehr dieser Bedrohungen)

Diese drei Säulen werden in einem iterativen Prozess kombiniert, der sich aus den folgenden drei Schritten zusammensetzt:

- Threat Intelligence
- Ermitteln und Umsetzen der Maßnahmen
- Testen der Effektivität der umgesetzten Maßnahmen

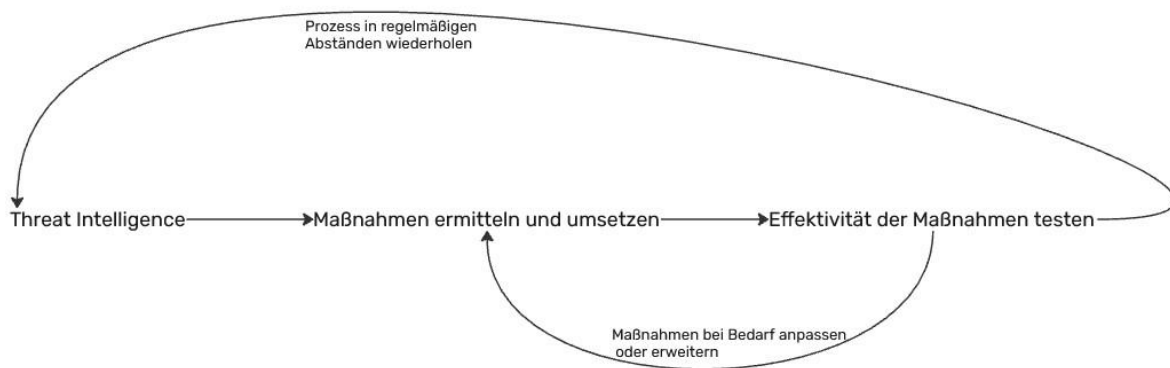


Abbildung 1 - Threat-Informed Defense Zyklus

In obiger Abbildung 1 ist der Zyklus der Threat-Informed Defense erkennbar.

Threat Intelligence ist der erste Schritt. Hier muss sich die Frage gestellt werden, gegen wen sich das Unternehmen schützen möchte. Dazu muss unter anderem beleuchtet werden, in welcher Branche sich das Unternehmen befindet und in welchen Ländern es operiert. Außerdem muss in Betracht gezogen werden, mit welchen Kunden oder Zulieferer das Unternehmen interagiert. Langfristige Trends wie Ransomware-as-a-Service (RaaS) sollten ebenfalls bedacht werden.

Aus diesen Punkten resultieren verschiedene Angreifergruppen, die ein theoretisches Interesse daran hätten, dieses Unternehmen zu attackieren. Nach Abschluss der Recherche werden die Informationen in die entsprechenden *TTPs* (*Tactics, Techniques und Procedures*) der Akteure umgesetzt. Dies erfolgt anhand des *MITRE ATT&CK Framework* (MITRE ATT&CK).

Als zweiter Schritt werden die *TTPs* priorisiert. Dies geschieht in enger Zusammenarbeit mit dem Unternehmen, da die Priorisierung sich für jedes Geschäftsmodell sowie Infrastruktur unterscheidet. Im Anschluss werden die Maßnahmen in der Infrastruktur implementiert. Bei der Auswahl geeigneter Maßnahmen hilft die *MITRE D3FEND Matrix* (D3FEND Matrix).

Wenn die Maßnahmen umgesetzt wurden, sollte ein Effektivitätstest dieser Maßnahmen stattfinden. Dazu werden die *TTPs* gezielt simuliert und gegen die Infrastruktur des Unternehmens getestet. Die Tests können sowohl automatisiert als auch manuell erfolgen. Typische Simulationen sind unter anderem Breach-and-Attack-Simulationen und Red-Team-Assessments.

Wofür ist es gut?

Threat-Informed Defense ermöglicht es Unternehmen, ihre Sicherheitsmaßnahmen auf die tatsächliche Bedrohungslage auszurichten. Um Schutz-, Erkennungs- und Reaktionsmechanismen gezielt zu definieren, wird sich an realen *TTPs* von Angreifern orientiert. Dies erhöht nicht nur die Effektivität vorhandener Sicherheitsvorkehrungen, sondern stärkt die Resilienz gegenüber aktuellen Angriffsmethoden.

Wo sind die Grenzen?

Threat-Informed Defense stellt keinen Ersatz für grundlegende Sicherheitsmaßnahmen oder ein vollständiges Framework dar. Voraussetzungen sind eine hochwertige Threat Intelligence und ein gewisses Maß an organisatorischer und technischer Reife. Sind nicht ausreichend Ressourcen, Kontextverständnis oder technische Umsetzungsmöglichkeiten vorhanden, so kann der tatsächliche Nutzen von Threat-Informed Defense stark eingeschränkt sein.

Womit kann man das vergleichen?

Threat-Informed Defense kann leicht mit einem risikobasierten, Angreifer-zentrierten Security-Engineering verglichen werden. Während klassische Ansätze wie Compliance-Frameworks (z. B. ISO 27001, NIST Cybersecurity Framework oder BSI IT-Grundschutz) auf generelle Anforderungen setzen, liegt der Fokus bei Threat-Informed Defense auf der konkreten Bedrohungslage und realen Angriffspfaden. Es ergänzt vorhandene Frameworks durch operative Relevanz, Aktualität und Angreiferfokussierung.

Wie verändert Threat-Informed Defense den Blick auf Risiken?

Klassisches Risikomanagement betrachtet Risiken primär anhand von Eintrittswahrscheinlichkeiten und potenziellen Auswirkungen. Diese methodische Abstraktion schafft Vergleichbarkeit und unterstützt strategische Entscheidungen, bleibt jedoch häufig auf einer theoretischen Ebene und berücksichtigt reale Angriffsmuster nur eingeschränkt.

Ansätze wie die szenariobasierte Risikoanalyse oder der IT-Grundschutz gehen bereits einen Schritt weiter, indem sie mit konkreten Bedrohungsszenarien und typischen Gefährdungen arbeiten. Sie verlassen damit die rein abstrakte Ebene und betrachten realistische Angriffsszenarien. Dennoch liegt der Fokus auch hier primär auf der Bewertung von Risiken anhand von Wahrscheinlichkeiten und Auswirkungen, während die operative Angriffsdynamik - konkrete Angriffspfade die Verkettung von Schwachstellen und tatsächliche Vorgehensweise von Angreifern - nicht im Zentrum der Betrachtung steht.

Threat-Informed Defense verschiebt den Fokus von abstrakten Risikomodellen hin zu konkreten Angriffsszenarien. Statt zu fragen, wie hoch ein Risiko theoretisch ist, wird analysiert, wie Angriffe in der Praxis tatsächlich ablaufen und welche Techniken von Angreifern eingesetzt werden. Sicherheitsmaßnahmen werden damit nicht nur geplant, sondern anhand realer Bedrohungen überprüft.

Diese Perspektivänderung ermöglicht eine realistische Bewertung der tatsächlichen Sicherheitslage. Risiken werden nicht mehr ausschließlich als Zahlen oder Kategorien verstanden, sondern als nachvollziehbare Angriffspfade mit klaren Annahmen. Dadurch lassen sich Prioritäten gezielter setzen und Schutzmaßnahmen wirksam an der realen Bedrohungslage ausrichten.

Wie kann die Wirksamkeit von Threat-Informed Defense gemessen werden?

Kennzahlen (*KPIs*) liefern einen konkreten, nachvollziehbaren Anhaltspunkt für die häufige Frage der Geschäftsführung nach der tatsächlichen Sicherheitslage. Im Kontext von Threat-Informed Defense geht es dabei weniger um formale Compliance-Kennzahlen, sondern um messbare Aussagen zur Wirksamkeit bestehender Sicherheitsmaßnahmen.

Zentrale KPIs sind dabei Mean Time to Detect (MTTD) und Mean Time to Respond (MTTR). Die Mean Time to Detect beschreibt den Zeitraum zwischen der Ausführung einer Angriffstechnik (TTP) und deren Erkennung durch bestehende Sicherheitsmechanismen. Eine kurze MTTD zeigt, dass Angriffe frühzeitig sichtbar werden und sich die Verweildauer von Angreifern im System reduziert.

Die Mean Time to Respond misst den Zeitraum zwischen der Erkennung einer Angriffshandlung und der Einleitung wirksamer Gegenmaßnahmen, beispielsweise der Isolierung eines Systems oder dem Blockieren eines Zugangs. Eine geringe MTTR ist entscheidend, um die Ausbreitung eines Angriffs zu begrenzen und Folgeschäden zu minimieren.

Ergänzend dazu eignet sich die TTP-Abdeckungsrate als strukturierender KPI. Sie beschreibt, welcher Anteil relevanter Angriffstechniken durch vorhandene Detektions- oder Präventionsmaßnahmen adressiert wird. Diese Kennzahl ermöglicht es, Sicherheitslücken gezielt zu identifizieren und Investitionen dort zu priorisieren, wo reale Angriffspfade bislang unzureichend abgedeckt sind.

In der Kombination erlauben diese Kennzahlen eine messbare, nachvollziehbare Bewertung der Sicherheitsfähigkeit. Sie übersetzen technische Erkenntnisse in eine Sprache, die sowohl für operative Teams als auch für Managemententscheidungen relevant ist.

Um die Effektivität der umgesetzten Maßnahmen zu testen, werden die *TTPs* gezielt simuliert und gegen die Infrastruktur des Unternehmens getestet. Dies kann unter anderem durch Breach-and-Attack-Simulationen und Red-Team-Assessments erfolgen.

Welche Erfahrungen gibt es?

Unternehmen und Organisationen, die Threat-Informed Defense anwenden, berichten von einer deutlich verbesserten Sichtbarkeit der aktuellen Bedrohungslage. Besonders hervorgehoben werden die daraus ableitbaren, klaren Handlungsempfehlungen und die Möglichkeit, relevante *KPIs* zur Bewertung der Sicherheitslage zu definieren. Durch die bedrohungsorientierte Priorisierung von Maßnahmen lassen sich Ressourcen gezielter einsetzen und bestehende Sicherheitsprozesse effektiver integrieren und pflegen.

Fazit

Threat-Informed Defense ist weit mehr als ein Instrument zur Priorisierung technischer und organisatorischer Maßnahmen. Der Ansatz ermöglicht es, Sicherheitsstrategien auf Basis fundierter Erkenntnisse über reale Angriffsmuster zu entwickeln und zu begründen.

Dadurch wird die Effektivität bestehender und geplanter Abwehrmechanismen transparent und messbar.

Darüber hinaus erweitert Threat-Informed Defense das klassische Risikomanagement um eine praxisnahe Perspektive. Statt abstrakter Risikobewertung werden konkrete Angriffsszenarien analysiert.

Voraussetzung für die erfolgreiche Anwendung von Threat-Informed Defense ist ein gewisser organisatorischer und technischer Reifegrad. Sind grundlegende Maßnahmen noch nicht etabliert, sollten zunächst die bekannten Probleme adressiert werden.

Fallbeispiel - Threat-Informed Defense anhand des initialen Vektors Phishing



Die obige Abbildung stellt die Heatmap¹ der Top 5 Ransomware-Gruppen in Deutschland dar.

Daraus lässt sich ableiten, dass die häufigsten initialen Eintrittsvektoren ins Unternehmen weiterhin die Nutzung bereits erbeuteter Anmeldedaten, das Ausnutzen von Schwachstellen exponierter Systeme, sowie jegliche Art von E-Mail-Angriffe (z. B. Phishing mit Link oder Anhang) sind.

Phishing nimmt hierbei eine zentrale Rolle ein. Es dient sowohl als direkter Eintrittsvektor als auch als vorbereitende Technik zur Kompromittierung gültiger Identitäten, die in späteren

¹ Die Heatmap wurde unter Zuhilfenahme des *MITRE ATT&CK Framework* (MITRE Att&CK) erstellt.

Angriffsphasen weiterverwendet werden. Vor diesem Hintergrund wird im folgenden Beispiel dargestellt, wie Threat-Informed Defense eingesetzt wird, um Phishing als initiale Angriffstechnik systematisch zu adressieren.

Schritt 1: Threat Intelligence

Im ersten Schritt werden relevante Phishing-Techniken identifiziert und analysiert. Betrachtet werden sowohl Phishing über Links und Anhänge als auch der anschließende Missbrauch abgegriffener Zugangsdaten.

Auf dieser Basis wird eine Bedrohungsannahme formuliert: Ein Angreifer nutzt gezielt Phishing-Nachrichten, um Anmeldedaten zu kompromittieren und diese für den initialen Zugriff auf Systeme zu verwenden. Diese Annahme bildet die Grundlage für alle weiteren Schritte.

Schritt 2: Ermitteln und Umsetzen der Maßnahmen

Ausgehend von den identifizierten TTPs werden gezielte Maßnahmen abgeleitet, die direkt auf das beobachtete Angreiferverhalten einzahlen. Ziel ist es, die Erfolgswahrscheinlichkeiten von Phishing zu reduzieren und die Auswirkungen eines erfolgreichen Angriffs zu begrenzen,

Technisch wird angesetzt, die Zustellung von Phishing-E-Mails zu erschweren und bösartige Inhalte frühzeitig zu erkennen. Ergänzend werden Identitäten gezielt abgesichert, um die Verwertbarkeit kompromittierter Zugangsdaten zu minimieren. Kontextbasierte Zugriffsbeschränkungen und der Verzicht auf veraltete Authentifizierungsverfahren erhöhen zusätzlich die Widerstandsfähigkeit gegenüber Missbrauch.

Daneben werden organisatorische Maßnahmen etabliert, um die Erkenntnisfähigkeit von Phishing zu verbessern und eine schnelle, standardisierte Reaktion auf bestätigte Vorfälle sicherzustellen. Alle Maßnahmen werden explizit den relevanten Angreifertechniken zugeordnet, um Transparenz über Abdeckung und Restrisiken zu schaffen.

Schritt 3: Testen der Effektivität

Die Wirksamkeit der umgesetzten Maßnahmen wird regelmäßig anhand realistischer Phishing-Szenarien überprüft. Dazu zählen Phishing-Simulationen, gemeinsame Übungen von Angriff und Verteidigung sowie die systematische Auswertung realer Sicherheitsvorfälle. Ziel ist es, Annahmen aus der Threat Intelligence kontinuierlich zu validieren und die Verteidigung iterativ anzupassen.

Zur Bewertung der Wirksamkeit werden phishing-spezifische KPIs eingesetzt, die direkt auf Phishing als Angriffstechnik ausgerichtet sind. Im Fokus stehen Kennzahlen zur Prävention, etwa die Erfolgsquote zugestellter Phishing-Mails oder die Absicherung von Identitäten sowie Kennzahlen zur Detektion, wie die Zeit bis zur Erkennung oder die Meldequote durch Benutzer. Ergänzend geben Reifegrad-Kennzahlen Aufschluss darüber, wie häufig Phishing-Interaktionen tatsächlich zu einer Kompromittierung führen.

Fazit

Das Fallbeispiel zeigt, wie Threat-Informed Defense genutzt werden kann, um Phishing als initialen Eintrittsvektor gezielt, messbar und iterativ zu adressieren. Durch die enge Verzahnung von Bedrohungsanalyse, Maßnahmenumsetzung und Wirksamkeitsmessung entsteht eine Verteidigungsstrategie, die sich an realen Angreifer-TTPs orientiert und kontinuierlich weiterentwickelt.

References

“MITRE Att&CK.” n.d. MITRE Att&CK. Accessed 04 14, 2026.

<https://attack.mitre.org/>.

“MITRE D3FEND Matrix.” n.d. MITRE D3FEND Matrix. Accessed 04 14, 2026.

<https://d3fend.mitre.org/>.



Sarah Obst

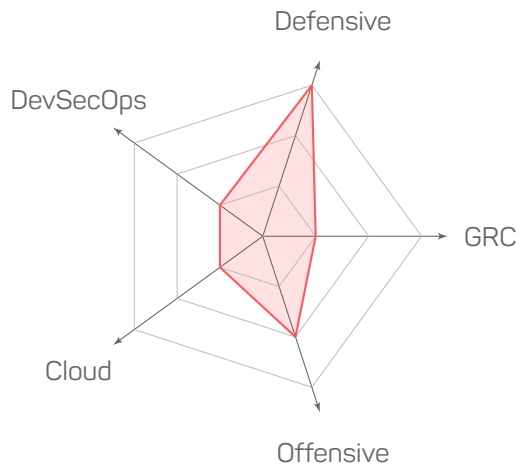
IT-Security Consultant

Sarah, fasziniert von Rätseln und Kriminalromanen, hat sich für ein Masterstudium in Digitaler Forensik entschieden, um reale Cyberfälle zu lösen. Jetzt verbindet sie ihre Leidenschaft für Ermittlungen mit Pentesting, um Schwachstellen aufzuspüren und Systeme sicherer zu machen.

mobil +49 (0) 1517 0603110

email sarah.obst@codecentric.de

Spezialgebiete



Zertifikate

- GIAC Certified Forensic Analyst
- Offensive Security Certified Professional



NOTFALL IT-SECURITY

- Krisenmanagement
- Incident Response
- Digitale Beweismittelsicherung
- Digitale Forensik
- Wiederaufbau-Management



OFFENSIVE IT-SECURITY

- Red Teaming
- Open Source Intelligence (OSINT)
- Phishing-Kampagnen
- Penetrationstests
 - Webapplikation
 - IT & OT



HOLISTISCHE IT-SECURITY

- KI-Security
- Bedrohungsanalysen
- Rapid Risk Assessment
- Threat Informed Defense
- SSDLC-Assessment (SAMMcentric)
- Cloud-Security Assessment
- IT-Security Workshops

KONTAKT

Webseite/E-Mail:

codecentric.de/it-security
it-security-projects@codecentric.de

codecentric IT-Security Vertrieb:

Marc Lenze, +49 15162959606

24/7 Notfallnummer bei IT-Sicherheitsvorfällen:
+49 212 25087062